Software Engineering & Security Principles: Secure Architecture and Threat Modeling

Logan K. Grace

Grand Canyon University

SWE-550-0500: Software Engineering & Security Principles

Hatim Alzoubi

Due: 11-11-2026

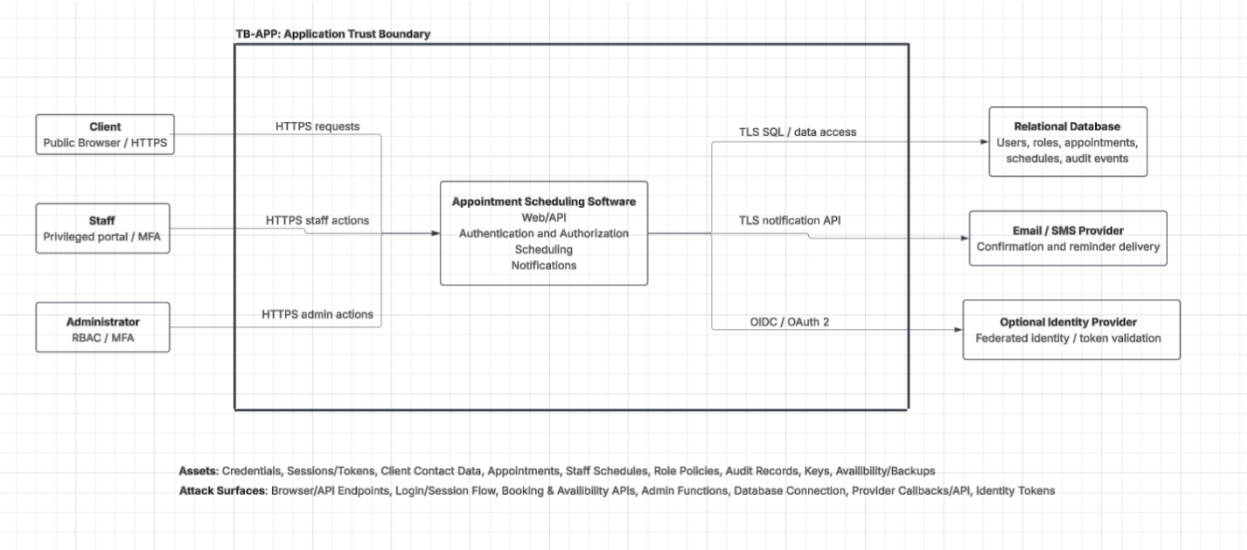
Version: -

Secure Architecture and Threat Modeling

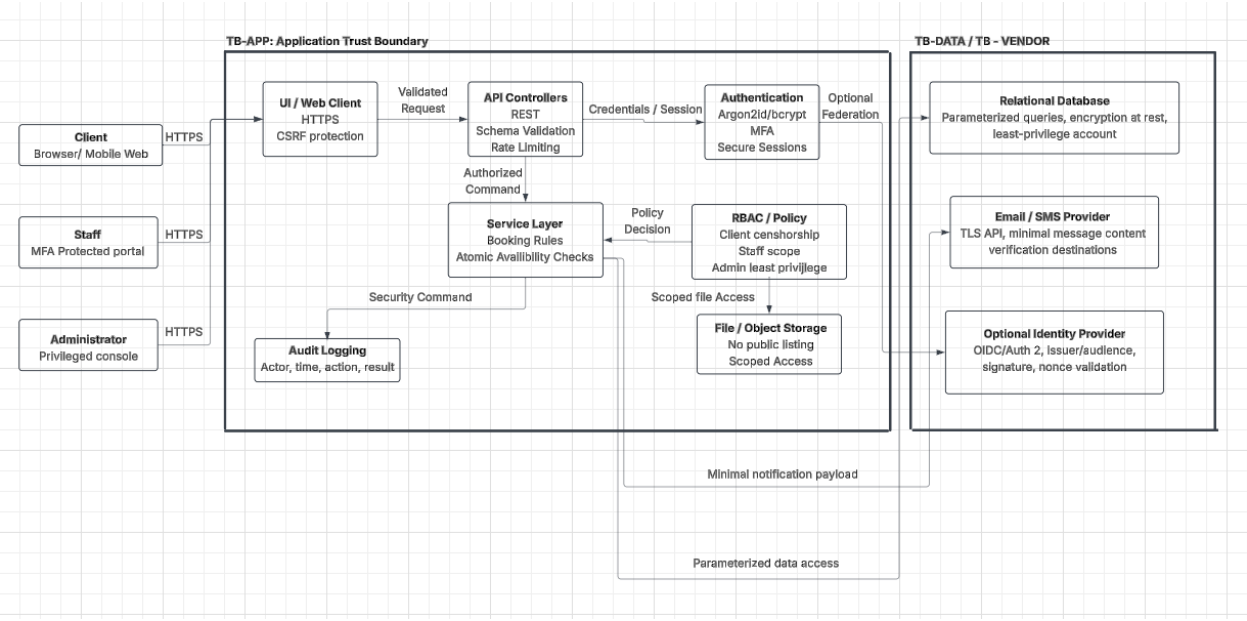
GitHub Repository: LGrace9784/appointment-scheduling: appointment software that allows the user to log in and book appointments

Level 0 & Level 1 Secure Architecture Diagrams

Level 0 System Context Diagram



Level 1 Component Architecture



Assets and Attack Surfaces		
Assets	**Attack Surfaces**	**Trust Boundaries**
• User information • Passwords hashes and authentication secrets • Session cookies • Appointment records • Staff availability • Role assignments • Notification content • Audit records • Application configuration • Uploaded files • Service availability	• Browser forms • REST endpoints • Login and recovery routes • Appointment lookup and availability endpoints • Admin functions • File upload • Database queries • Provider APIs • Identity provider token handling	• TB-USER • TB-ROLE • TB-DATA • TB-MSG • TB-IDP • TB-LOG • TB-FILE

STRIDE Analysis and Threat Model Documentation

STRIDE Coverage with Data Flow Table

Flow ID	Data flow / boundary	STRIDE categories	Analysis
F1	Public client/staff/admin > HTTPS UI/API	Spoofing, Tampering, DoS	Identity claims, request data and service availability cross from untrusted devices to the application. Apply TLS, validation, authentication, CSRF protections and rate limiting.
F2	API/controller > Authentication service	Spoofing, Information Disclosure	Credentials and session/token material are highly sensitive. Hash passwords with adaptive hashing; never log secrets; rotate and protect sessions.
F3	API/service > RBAC policy decision	Elevation of Privilege, Spoofing	Role and ownership decisions determine permitted actions. Enforce server-side deny-by-default authorization on every request.
F4	Scheduling service > Database	Tampering, Information Disclosure	Appointment and schedule records cross the application/data boundary. Use parameterized queries, least-privilege DB identity, encryption at rest and transactional booking.
F5	Application > Email/SMS provider	Information Disclosure, Tampering	Contact details and notification content leave the application boundary. Use TLS, minimal payloads, verified destinations and protected API credentials.
F6	Application <>optional identity provider	Spoofing, Tampering	Federated tokens cross a vendor boundary. Validate signature/issuer/audience/expiry/state/nonce and fail closed.
F7	Application components > audit pipeline	Repudiation, Information Disclosure, Tampering	Security events leave runtime components. Redact secrets, restrict write/read access, preserve integrity and monitor delivery failures.
F8	Service > file/object storage (conditional)	Information Disclosure, Tampering	Files cross an application/storage boundary. Private storage, scoped authorization, malware scanning and short-lived access links are required.

Threat Model Table

Threat ID	Affected component/data flow	STRIDE	Threat description	Risk level	Likely impact	Mitigation
T-01	Authentication / session flow (UI<>Auth)	Spoofing	Credential stuffing, password guessing, or session theft enables account takeover.	High	Unauthorized access to client records; staff/admin compromise could expose or alter many appointments.	Adaptive password hashing; MFA for staff/admin; secure HttpOnly/SameSite cookies; session rotation/expiry; rate limits; breached-password checks; alert on anomalies.
T-02	API > Service > Database (appointment lookup)	Information Disclosure	A client changes an appointment identifier and retrieves another client's record (IDOR/BOLA).	High	Exposure of names, contact details, appointment times and service metadata; privacy and trust damage.	Enforce ownership and role scope in every server-side operation; deny by default; opaque IDs are defense-in-depth only; authorization regression tests.
T-03	API / Service > Database (booking writes)	Tampering	Concurrent or manipulated booking requests bypass availability checks and create conflicting appointments.	High	Double bookings, corrupted schedules, operational disruption and disputes.	Perform availability check and insert in one transaction; unique/exclusion constraint where feasible; idempotency key; concurrency tests.
T-04	UI/API input > Service > Database	Tampering	SQL injection or unsafe input causes unauthorized query behavior or stored data manipulation.	High	Data theft, record modification, or application compromise.	Server-side allowlist validation; parameterized queries/ORM safe APIs; output encoding; length/type limits; security tests.
T-05	Staff/admin authentication and RBAC boundary	Elevation of Privilege	A compromised or over-privileged staff account performs administrator actions or accesses unrelated schedules.	High	Bulk appointment changes, role manipulation, schedule disruption, or broad data exposure.	MFA; least-privilege RBAC; separate admin permissions; scoped staff access; periodic access review; audit role/policy changes.
T-06	Application > Email/SMS provider	Information Disclosure	Notification payload or misconfigured recipient reveals unnecessary appointment details to the wrong recipient or vendor account.	Medium	Personal information disclosed through message previews, wrong-number delivery, or vendor compromise.	Minimize message content; verify destination; TLS; restrict provider credentials; avoid sensitive subject/body content; retention review.
T-07	Login / availability API public endpoints	Denial of Service	Automated traffic exhausts authentication or availability resources and prevents legitimate bookings.	High	Service outage, missed appointments, degraded access and support burden.	Rate limiting by account/IP/device signals; progressive backoff; bot detection; capacity monitoring; graceful degradation; alerting.
T-08	Audit logging and monitoring pipeline	Repudiation	An actor denies a sensitive action because events are missing, mutable, or lack actor/time/outcome context.	Medium	Investigation gaps, inability to attribute cancellations or role changes, compliance weaknesses.	Log actor, timestamp, action, target and outcome; append-only/centralized storage; restricted log access; clock sync; alert on log pipeline failure.
T-09	Optional Identity Provider token boundary	Spoofing	Application accepts forged, expired, wrong-issuer, or wrong-audience identity tokens.	Medium	Unauthorized account access or role confusion through federated login.	Validate signature, issuer, audience, expiry, nonce and state; use approved algorithms; rotate keys; fail closed; disable federation if not configured.
T-10	File/object storage (if attachments enabled)	Information Disclosure	Predictable object keys or permissive storage policies expose uploaded documents or metadata.	Medium	Unauthorized access to personal documents and expanded breach scope.	Keep bucket private; authorize every download; short-lived signed URLs; malware/type/size checks; encryption at rest; omit attachments from MVP unless required.

Security Requirements and Architecture Controls

See Below a reminder of my topic 1 security requirements

ID	Requirement	Stakeholder or Asset	Threat	Risk Reduction
SR-01	Store passwords only as satled hashes	Clients and credentials	AC1	Limits damage from credential exposure
SR-02	Require authenticated session for protected functions and enforce server-side role authorization	All roles with appointments and permissions	AC2, AC4	Blocks access beyond the user's permission
SR-03	Confirm appointment ownership before a client can view or make changes	Clients and appointment records	AC2	Prevents cross-client record access
SR-04	Atomical bookings and availability checking	Clients/staff and schedules	AC3	Prevents double bookings
SR-05	TLS is used for external connections and secure sessions	All users with sessions and contact data	AC1, AC6	Protects data in transit and reduces session theft
SR-06	Validate and encode input server-side	All users and database	AC5	Reduces injection and unsafe-rendering risks
SR-07	Require MFA for staff and admin	Staff/admin with roles and schedules	AC4	Reduces the impact of stolen passwords
SR-08	Rate-limit authentication and availability requests	All users with service availability	AC1, AC7	Slows credential attacks
SR-09	Log security resolutions	Admin with audit logins	AC2, AC4, AC6	Supports investigation without keeping secrets
SR-10	Minimize appointment informations	Clients with notification data	AC6	Limits disclosure if message are misdirected

Architecture Controls	
Authentication	Authentication service verifies the identity, stores password hashes, and issues short lived sessions. Staff and administrators require MFA. Session's cookies are secure. Session identifiers rotate after authentication

Role-based Access Control	API invokes server-side authorization. Clients are limited to their records only, staff access is scoped, administrators get only needed privileges. Authorization is denied by default.
Input Validation	Controllers validate request schemas and allow values before service execution. Data-access layer uses parameterized queries or safe ORM methods. Output is encoded for its destination context. Validation errors do not reveal traces or internal implementation.
Encryption	APIs, database, and vendor communication. Sensitive, stored data and backups are encrypted via managed keys. Secrets and provider credentials are stored outside source control in secret store.
Audit Logging	Security relevant events record proper information like time and target. Passwords and unneeded appointment details are removed. Log access is restricted and storage should be provided only. Alerts cover questionable behavior in the system.
Rate Limiting	Login and recovery use throttling and progressive backoff. Limits combine account and network/device signals to limit credential stuffing.
File Storage	Attachments not required for MVP. Storage is private, authorized access is allowed by request, downloads are short

	lived signed links. This prevents an unreviewed public bucket from exposure.
External Systems	Email/SMS messages contain minimal information. OIDC/OAuth federation is disabled unless configured. If enabled application validates token and other fields

Threat Prioritization and Mitigation Roadmap

Refer to the previous threat table for more information if needed

Priority	Threat	Risk	Reason	Mitigation	Phase
1	T-01	High	Compromise exposes data and can give path to admin access. Identity is a prerequisite for every protected workflow	Hashing, MFA for staff/admin; secure sessions; login throttling	Milestone 3
2	T-02	High	Single predictable identifier manipulation exposes clients private records	Severside ownership checks; role scopes; authorization tests	Milestone 3
3	T-03	High	Conflicting reservations undermine purpose of application	Atomic transaction; idempotency and concurrency tests	Milestone 3
4	T-04	High	Unsafe input can alter queries or expose/modify broad data	Schema Validation; output encoding; secrurity tests	Milestone 3
5	T-05	High	Staff functions affect several clients and schedules. Overpowered roles	MFA; scoped staff permissions; safeguarded admin actions	Milestone 3

Backlog Update with Timeline

ID	Task	Area	Priority	Target phase	Acceptance criteria
SEC-01	Implement adaptive password hashing and secure account recovery	Authentication	Must	Milestone 3 – Design	Unit tests verify hashes are salted/adaptive; no plaintext credentials in logs or database.
SEC-02	Add MFA for staff and administrators	Authentication	Must	Milestone 3 – Design	Staff/admin login requires second factor; recovery flow is tested.
SEC-03	Implement server-side RBAC and appointment ownership checks	Authorization	Must	Milestone 3 – Design	Client A cannot read/update Client B records; staff scope and admin permissions tested.
SEC-04	Add API schema validation, output encoding and parameterized data access	Input security	Must	Milestone 3 – Design	Invalid types/lengths rejected; injection test cases do not alter query structure.
SEC-05	Make booking creation atomic and prevent double booking	Data integrity	Must	Milestone 3 – Design	Concurrent booking test permits only one reservation for a conflicting slot.
SEC-06	Configure TLS, secure session cookies and session lifecycle controls	Transport/session	Must	Milestone 3 – Design	HTTPS enforced; cookies HttpOnly/Secure/SameSite; session rotation and expiry verified.
SEC-07	Add login and availability endpoint rate limiting	Availability	Should	Milestone 3 – Design	Threshold tests show throttling while normal users can continue after cooldown.
SEC-08	Create tamper-resistant audit events and alerting	Monitoring	Should	Milestone 4 – integration/testing	Actor/time/action/outcome recorded; secrets redacted; unauthorized log edits prevented.
SEC-09	Minimize notification content and secure provider integration	Privacy/integration	Should	Milestone 4 – integration/testing	Messages disclose minimum data; provider credentials protected; delivery failures logged.
SEC-10	Validate optional OIDC/OAuth tokens or keep federation disabled	Federation	Could	Milestone 4 – integration/testing	If enabled, invalid issuer/audience/signature/expiry rejected; otherwise feature flag remains off.
SEC-11	Define private file storage controls before enabling attachments	Storage	Could	Milestone 4 – integration/testing	No public bucket/listing; each download is authorized; file scanning and size/type checks pass.
SEC-12	Run threat-focused security verification and close high risks	Security testing	Must	Milestone 5 – security verification	Authorization, injection, concurrency, rate-limit and logging tests pass; residual risks documented.